

Travaux Dirigés

Authentification avec PHP & MySQL

Arborescence du projet

Créez la structure de fichiers suivante dans votre répertoire de travail :

```
auth-td/  
├── config/  
│   └── db.php  
├── register.php  
├── login.php  
├── logout.php  
├── dashboard.php  
└── includes/  
    └── auth_check.php
```

Base de données MySQL

Exécutez le script SQL suivant dans phpMyAdmin ou en ligne de commande :

```
CREATE DATABASE IF NOT EXISTS auth_td  
CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;  
USE auth_td;  
  
CREATE TABLE utilisateurs (  
  id          INT UNSIGNED AUTO_INCREMENT PRIMARY KEY,  
  nom         VARCHAR(100) NOT NULL,  
  email       VARCHAR(180) NOT NULL UNIQUE,  
  mot_passe   VARCHAR(255) NOT NULL,  
  cree_le    DATETIME DEFAULT CURRENT_TIMESTAMP  
);
```

Exercice 1 — Connexion PDO

Créez le fichier config/db.php et complétez les champs manquants :

```
<?php  
$host    = '127.0.0.1';  
$db      = 'auth_td';  
$user    = '??';      // votre utilisateur MySQL  
$pass    = '??';      // votre mot de passe MySQL  
$charset = 'utf8mb4';  
  
$dsn = "mysql:host=$host;dbname=$db;charset=$charset";  
$options = [  
    PDO::ATTR_ERRMODE            => PDO::ERRMODE_EXCEPTION,  
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
```

```

        PDO::ATTR_EMULATE_PREPARES    => false,
    ];

    try {
        $pdo = new PDO($dsn, $user, $pass, $options);
    } catch (PDOException $e) {
        error_log($e->getMessage());
        die('Erreur de connexion à la base de données.');
```

Exercice 2 — Inscription

Implémentez `register.php` avec validation complète des données saisies :

```

<?php
session_start();
require 'config/db.php';

$erreurs = [];
$succes  = false;

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $nom  = trim($_POST['nom'] ?? '');
    $email = trim($_POST['email'] ?? '');
    $mdp  = $_POST['mot_passe'] ?? '';
    $mdp2 = $_POST['mot_passe2'] ?? '';

    // Validation
    if (strlen($nom) < 2)
        $erreurs[] = 'Le nom doit contenir au moins 2 caractères.';
    if (!filter_var($email, FILTER_VALIDATE_EMAIL))
        $erreurs[] = 'Adresse email invalide.';
    if (strlen($mdp) < 8)
        $erreurs[] = 'Mot de passe trop court (min. 8 caractères).';
    if ($mdp !== $mdp2)
        $erreurs[] = 'Les mots de passe ne correspondent pas.';

    // Email déjà utilisé ?
    if (empty($erreurs)) {
        $stmt = $pdo->prepare('SELECT id FROM utilisateurs WHERE email = ?');
        $stmt->execute([$email]);
        if ($stmt->fetch()) $erreurs[] = 'Cet email est déjà utilisé.';
    }

    // Insertion
    if (empty($erreurs)) {
        $hash = password_hash($mdp, PASSWORD_BCRYPT);
        $stmt = $pdo->prepare(
            'INSERT INTO utilisateurs (nom, email, mot_passe) VALUES (?, ?, ?)'
        );
        $stmt->execute([$nom, $email, $hash]);
        $succes = true;
    }
}

// ... HTML du formulaire ci-dessous
```

À faire

1. Écrivez le formulaire HTML avec les champs : nom, email, mot_passe, mot_passe2.

2. Affichez les erreurs dans \$erreurs sous le formulaire.
3. Affichez un message de succès si \$succes === true.

Exercice 3 — Connexion & Sessions

Implémentez login.php avec vérification du mot de passe et gestion de session :

```
<?php
session_start();
require 'config/db.php';

$erreur = '';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $email = trim($_POST['email'] ?? '');
    $mdp    = $_POST['mot_passe'] ?? '';

    $stmt = $pdo->prepare(
        'SELECT id, nom, mot_passe FROM utilisateurs WHERE email = ?'
    );
    $stmt->execute([$email]);
    $user = $stmt->fetch();

    if ($user && password_verify($mdp, $user['mot_passe'])) {
        session_regenerate_id(true); // Protection fixation de session
        $_SESSION['user_id'] = $user['id'];
        $_SESSION['user_nom'] = $user['nom'];
        header('Location: dashboard.php');
        exit;
    } else {
        $erreur = 'Email ou mot de passe incorrect.'; // Message volontairement
        vague
    }
}
```

Questions

- Pourquoi le message d'erreur est-il volontairement vague ("Email ou mot de passe incorrect") ?
- Que se passe-t-il si on supprime le paramètre true de session_regenerate_id() ?
- Pourquoi ne stocke-t-on PAS le mot de passe en session ?

Exercice 4 — Protection des pages

Fichier includes/auth_check.php

Ce fichier est inclus en haut de chaque page protégée :

```
<?php
if (session_status() === PHP_SESSION_NONE) {
    session_start();
}
```

```
if (empty($_SESSION['user_id'])) {  
    header('Location: login.php');  
    exit;  
}
```

Fichier dashboard.php

```
<?php  
require 'includes/auth_check.php';  
require 'config/db.php';  
  
$nom = htmlspecialchars($_SESSION['user_nom']);  
?>  
<!DOCTYPE html>  
<html>  
<body>  
    <h1>Bienvenue, <?= $nom ?> !</h1>  
    <a href="logout.php">Se déconnecter</a>  
</body>  
</html>
```

Fichier logout.php

```
<?php  
session_start();  
$_SESSION = [];  
session_destroy();  
header('Location: login.php');  
exit;
```

Questions

- Pourquoi appelle-t-on `$_SESSION = []` avant `session_destroy()` ?
- Pourquoi utilise-t-on `htmlspecialchars()` sur le nom en session ?
- Que se passe-t-il si on oublie `exit` après le `header('Location:...')` ?

Bon courage !